Policy As Code

Usando Kyverno para Garantir Segurança e Compliance

Eduardo Munari

Flávio Meira



Todas as opiniões apresentadas aqui **são dos autores** e **não representam** as posições de suas respectivas empresas

All opinions expressed here are **those of the authors** alone and **do not represent** their respective organizations

Eduardo

Staff Technical Product

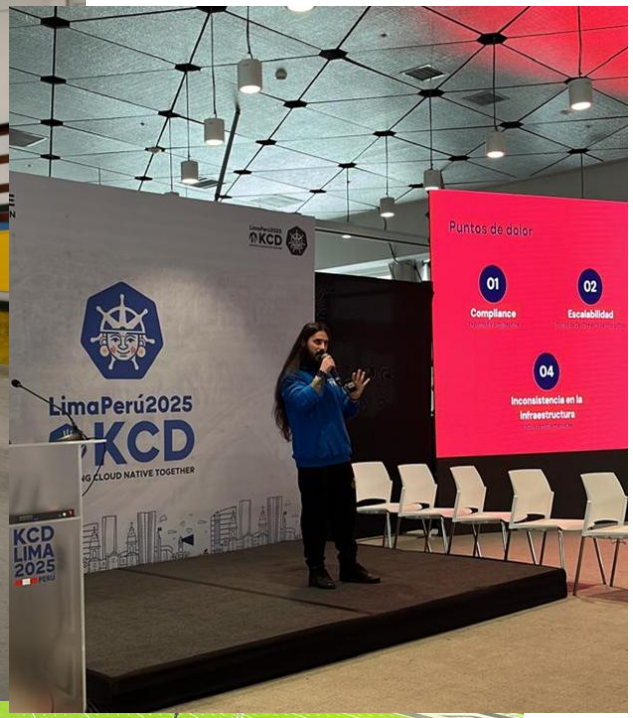
Manager @ Stone

Containers && \

Platform Engineering Specialist

Golden Kubestronaut





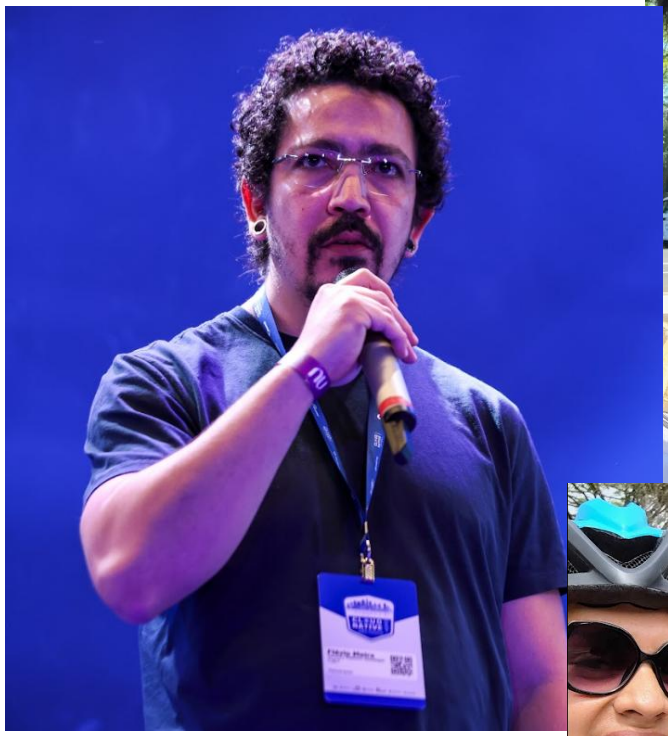




Flávio

Platform Engineer @ CI&T

Security Specialist





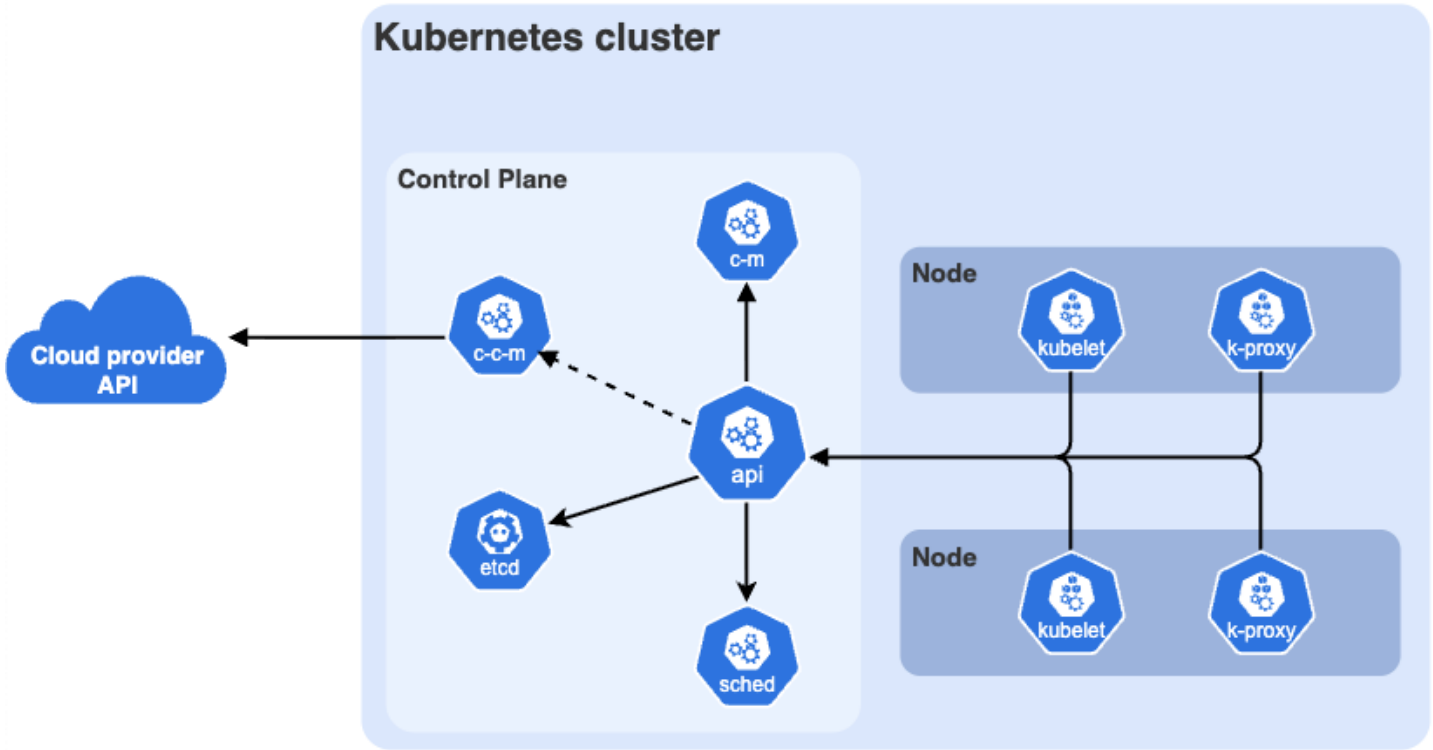


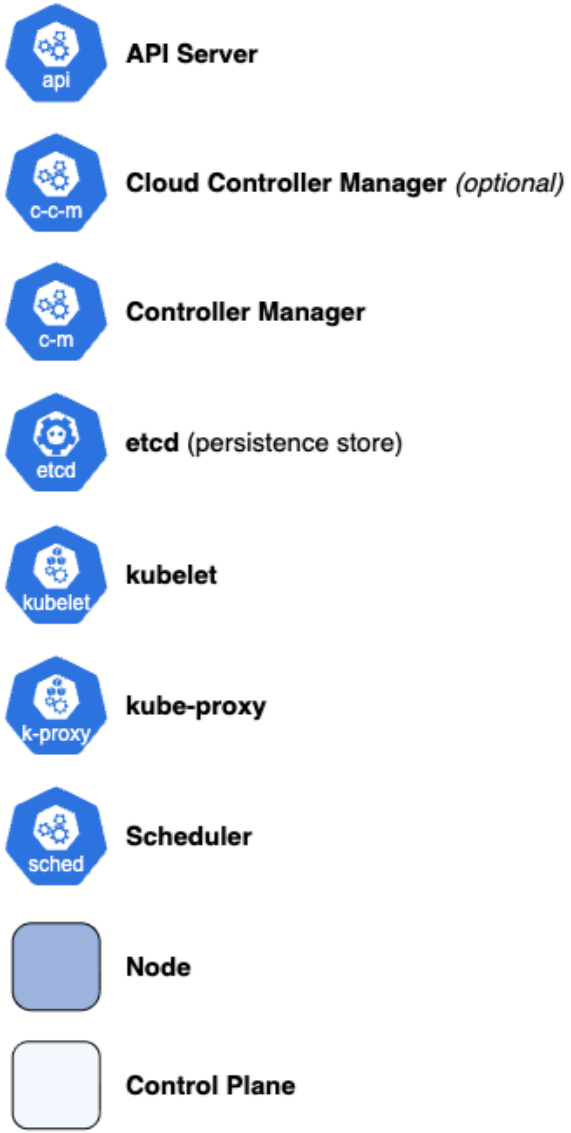
kubernetes AND CLOUD NATIVE ASSOCIATE

Agenda

- ***Arquitetura K8s***
  - **kube-api**
  - **admission control**
- ***Kyverno 101***
    - **Why Kyverno? - PSS vs Kyverno**
    - **ClusterPolicy - deixando seu cluster seguro**
      - **Policy rules - estruturas das cluster policies**
      - **Policy settings - configurações específicas**
    - **Policy Exception - exceções sem alterar as policies**
    - **Cleanup Policy - removendo recursos de forma periódica**
    - **Dynamic Admission Controller**
- ***Use Cases -*** *Explorando e remediando vulnerabilidades!*
  - **Seccomp - Impedindo chamadas ao kernel**
  - **Restringindo privilégios - Impedindo interação com arquivos do host**
- ***Métricas -*** *Monitorando as operações de segurança*

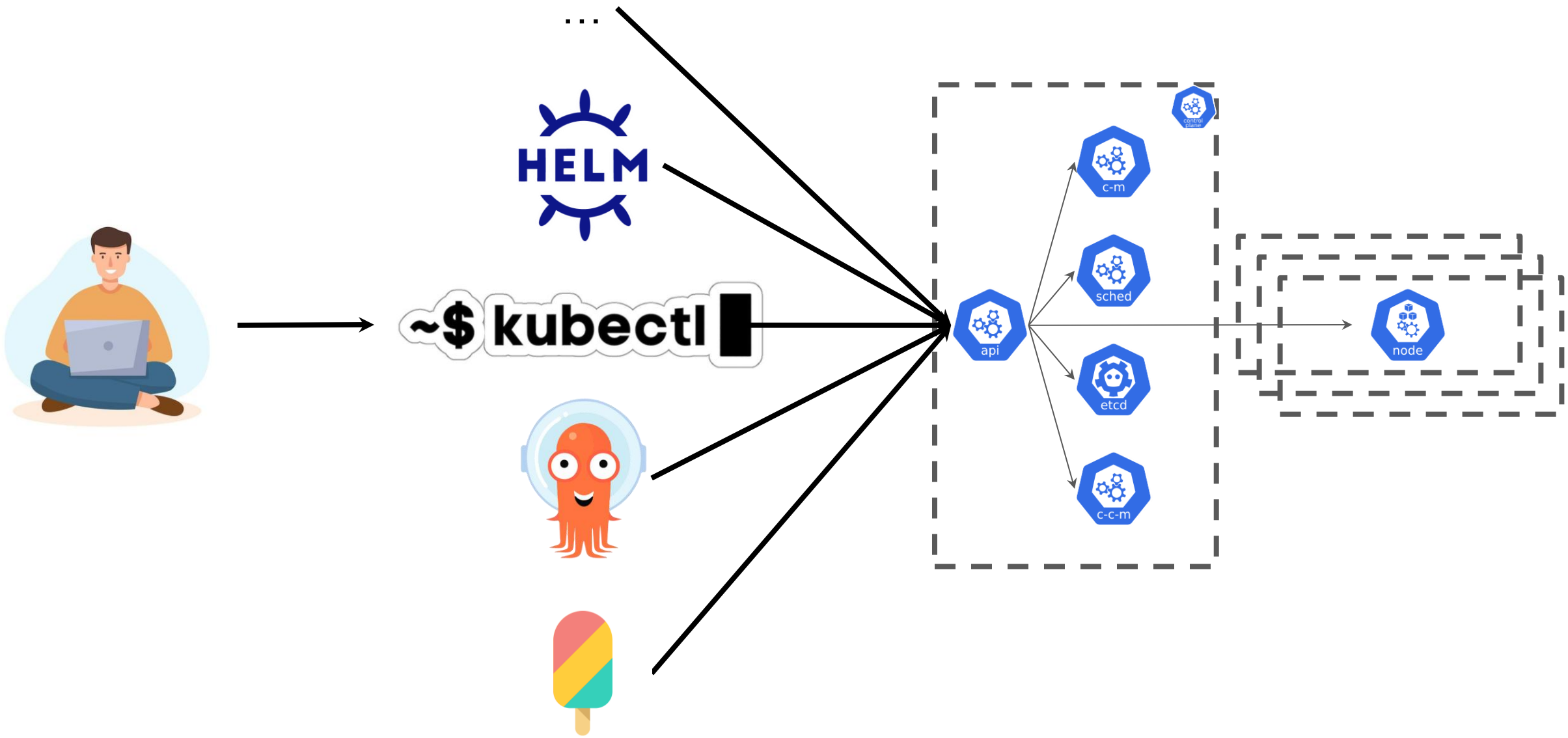
Arquitetura k8s



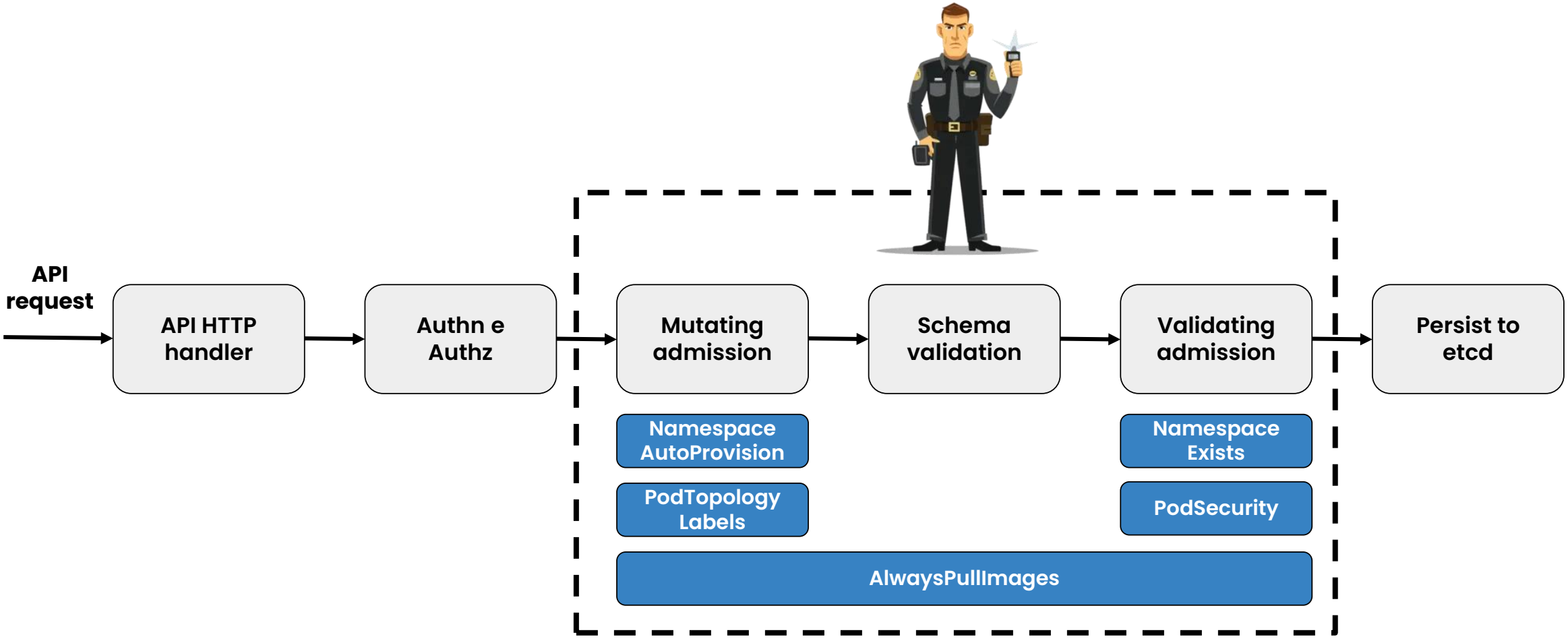


https://kubernetes.io/docs/concepts/overview/components/

Arquitetura k8s - kube-api



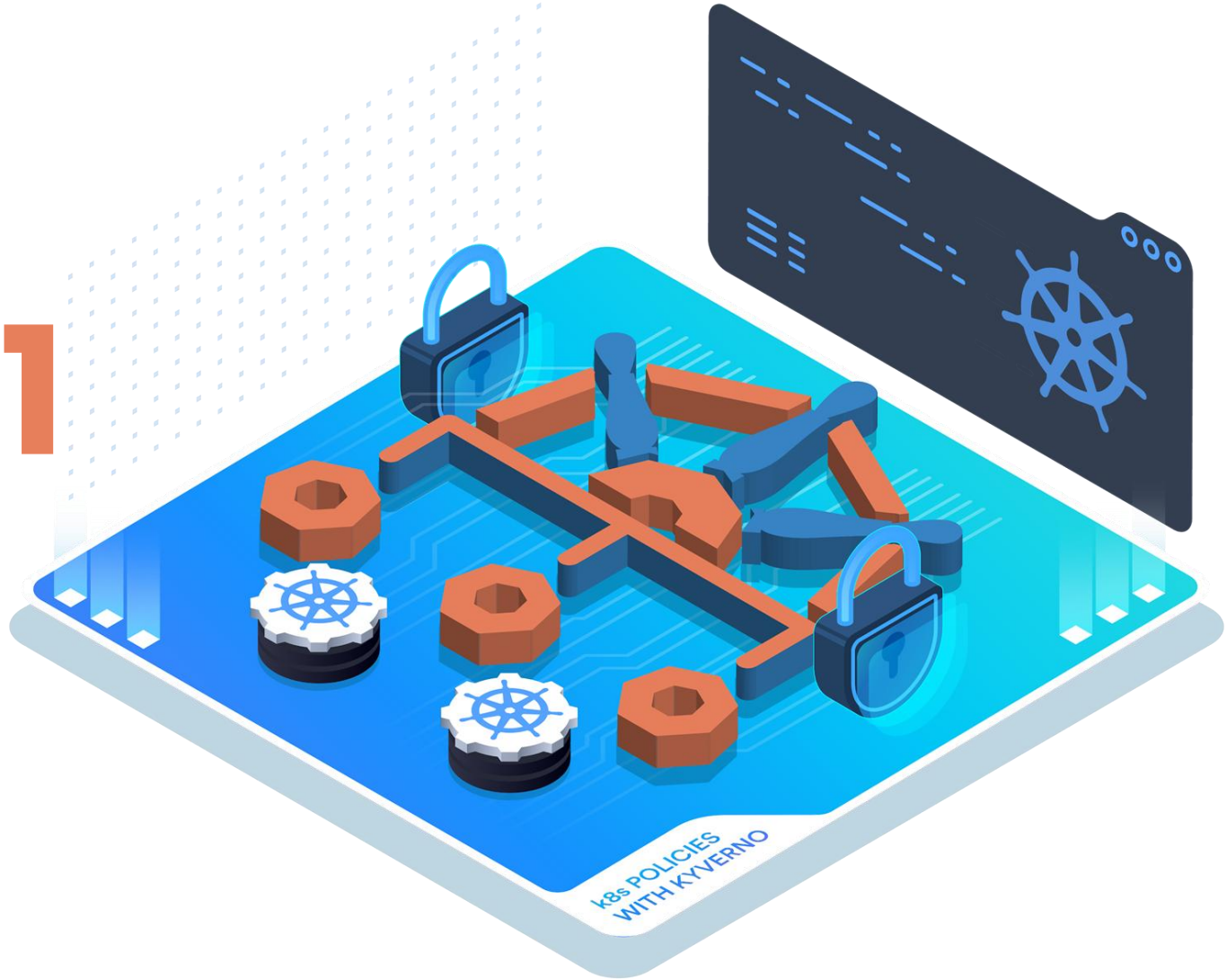
Arquitetura k8s - Admission Control



https://kubernetes.io/docs/reference/access-authn-authz/admission-controllers/

Kyverno 101

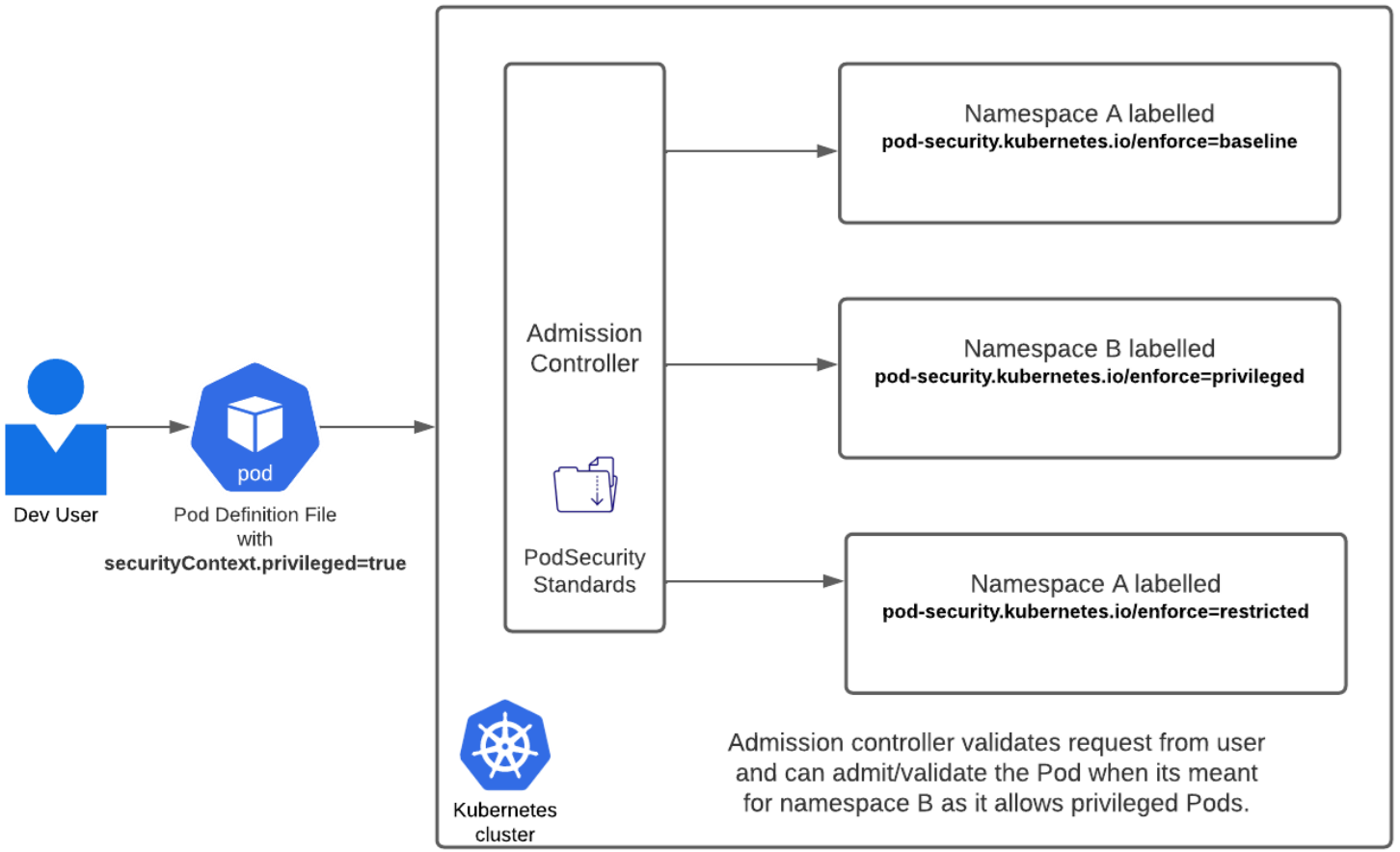
Políticas e compliance sob medida



Why Kyverno?

Policy Security Standard (PSS)

- Não permite granularidade
  - privileged, baseline, restricted
  - enforce, warn, audit
- namespace-wide
- Não aplica mutação
- Não possui regras condicionais

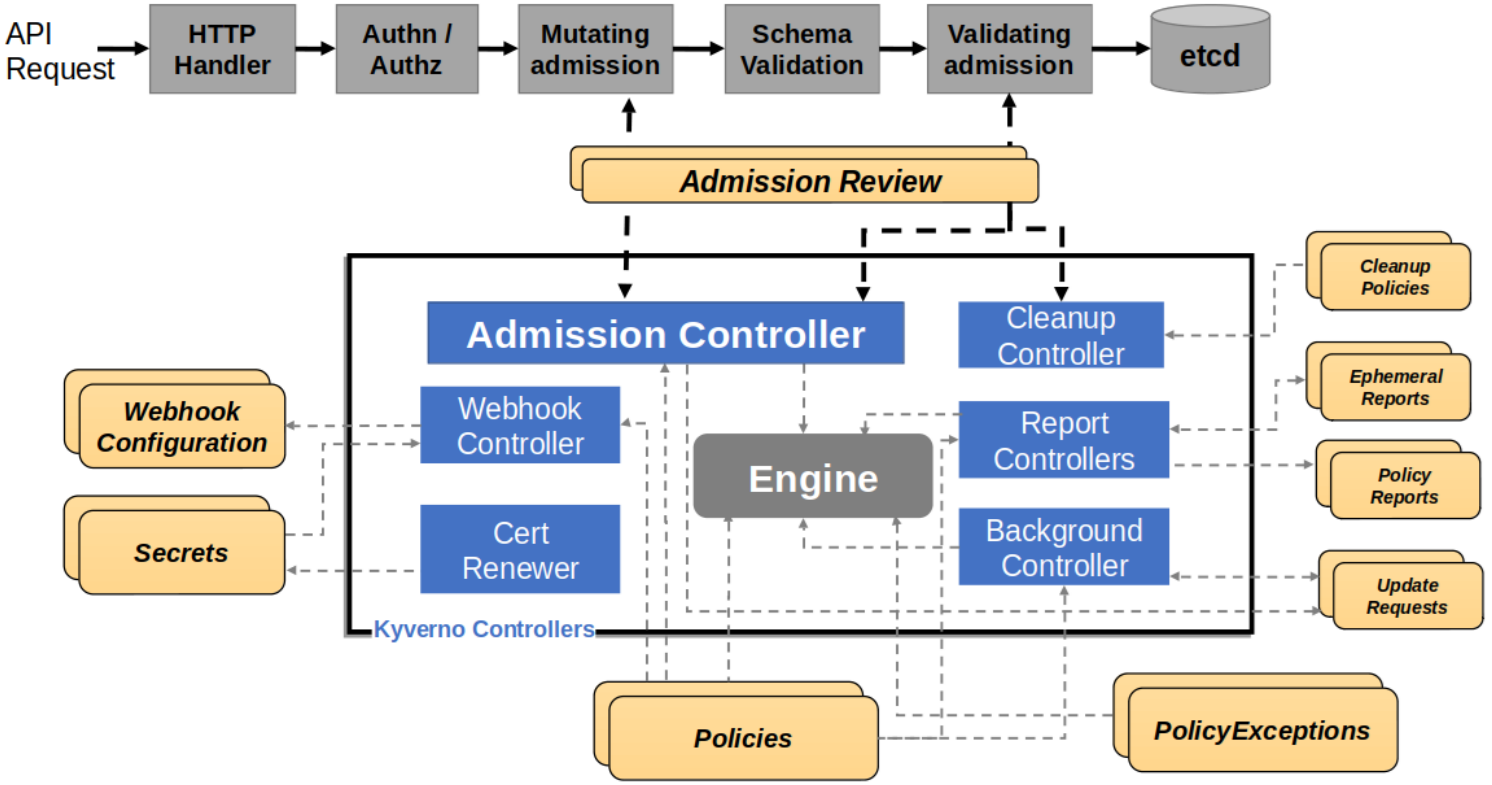


https://kubernetes.io/docs/concepts/security/pod-security-standards/

Why Kyverno?

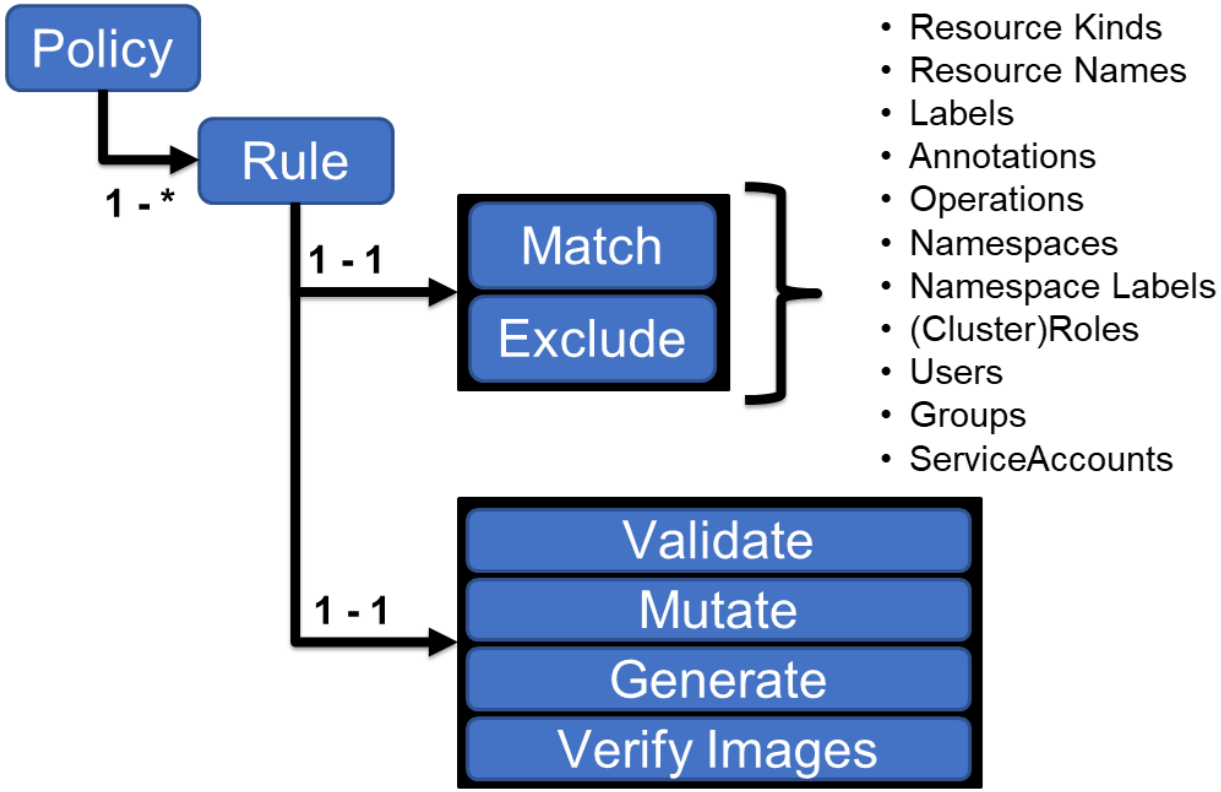
Kyverno

- **Granularidade**: Permite políticas por qualquer campo: kind, name, label etc
- Possibilita o uso do padrão JSON Patch
- Flexibilidade para aplicar mutação em objetos específicos com condicionais
- **Auditoria**: Relatórios de compliance



https://kyverno.io/docs/introduction/how-kyverno-works/

ClusterPolicy



https://kyverno.io/docs/policy-types/cluster-policy/policy-rules/

PolicyRules

Validate

- Valida regras das policies via **Validation Admission**
- Analisa campos especificados no objeto que está sendo criado
- Aplica regras utilizando operações pré-definidas: match, exclude e condições
- Aplica ações: permite, bloqueia ou audita

```yaml
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: require-ns-purpose-label
spec:
  rules:
  - name: require-ns-purpose-label
    match:
      any:
      - resources:
          kinds:
          - Namespace
    validate:
      failureAction: Enforce
      message: "You must have label `purpose` with value `production` set on all new- namespaces."
      pattern:
        metadata:
          labels:
            purpose: production
```

https://kyverno.io/docs/policy-types/cluster-policy/validate/

PolicyRules

Mutate

- Atua na fase **Mutating Admission** da API
- Modifica o objeto que está sendo criado
- Insere, altera ou sobrescreve valores dos objetos
- Garante que todos os objetos tenham configurações pré-definidas

```yaml
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: set-image-pull-policy
spec:
  rules:
    - name: set-image-pull-policy
      match:
        any:
        - resources:
            kinds:
            - Pod
      mutate:
        patchStrategicMerge:
          spec:
            containers:
              - (image): "*:latest"
                imagePullPolicy: "IfNotPresent"
```

https://kyverno.io/docs/policy-types/cluster-policy/mutate/

PolicyRules

Generate

- Gera recursos auxiliares
  - secrets
  - configmaps
  - network policies
- Clona recursos existentes ou cria novos
- Opção de manter objetos sincronizados
- Observam recursos que dão match com API configurada na policy

```yaml
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: default
spec:
  rules:
  - name: deny-all-traffic
    match:
      any:
      - resources:
          kinds:
          - Namespace
    exclude:
      any:
      - resources:
          namespaces:
          - kube-system
          - default
          - kube-public
          - kyverno
    generate:
      kind: NetworkPolicy
      apiVersion: networking.k8s.io/v1
      name: deny-all-traffic
      namespace: "{{request.object.metadata.name}}"
      data:
        spec:
          # select all pods in the namespace
          podSelector: {}
          policyTypes:
          - Ingress
          - Egress
```

https://kyverno.io/docs/policy-types/cluster-policy/generate/

PolicyRules

VerifyImages

- Checa assinaturas nas imagens
  - garante autenticidade
  - permite apenas imagens assinadas

- Detecta e bloqueia imagens alteradas
  - Converte tags em digests

- Garante auditoria automatizada
  - SOX

```yaml
apiVersion: kyverno.io/v2beta1
kind: ClusterPolicy
metadata:
  name: check-image-notary
spec:
  webhookConfiguration:
    failurePolicy: Fail
    timeoutSeconds: 30
  rules:
    - name: verify-signature-notary
      match:
        any:
        - resources:
            kinds:
              - Pod
      verifyImages:
      - type: Notary
        imageReferences:
        - "ghcr.io/kyverno/test-verify-image*"
        failureAction: Enforce
        attestors:
        - count: 1
          entries:
          - certificates:
              cert: |-
                -----BEGIN CERTIFICATE-----
                MIIDTTCCAj...
                -----END CERTIFICATE-----
```

https://kyverno.io/docs/policy-types/cluster-policy/verify-images/

Policy Settings

- **validationFailureAction**: Apenas audita ou audita e bloqueia
- **validationFailureActionOverrides**: Faz override na **validationFailureAction** para namespaces específicos
- **background**: Varre recursos existentes aplicando as políticas criadas
- **admission**: Desabilita aplicação da policy na camada de Admission Control. As validações são feitas apenas em background
- **failurePolicy**: Define o comportamento caso o Webhook não responda. Valores possíveis são “Ignore” ou “Fail”. Defaults to “Fail”
- **webhookConfiguration.timeoutSeconds**: Tempo máximo de espera da resposta do Webhook. Default é 10s. Precisa estar entre 1 e 30 segundos

https://kyverno.io/docs/policy-types/cluster-policy/policy-settings/

PolicyException



Criar exceções dentro da policy exige editar a regra sempre que alguém precisa de exceção



A **PolicyException** permitie exceções externas, temporárias e controladas, sem editar a policy



As **policies** continuam estáveis e seguras, enquanto as exceções ficam auditáveis, rastreáveis e independentes



Não habilitadas por default

```yaml
apiVersion: kyverno.io/v2
kind: PolicyException
metadata:
  name: delta-exception
  namespace: delta
spec:
  exceptions:
  - policyName: disallow-host-namespaces
    ruleNames:
    - host-namespaces
    - autogen-host-namespaces
  match:
    any:
    - resources:
        kinds:
        - Pod
        - Deployment
        namespaces:
        - delta
        names:
        - important-tool*
  conditions:
    any:
    - key: "{{ request.object.metadata.labels.app || '' }}"
      operator: Equals
      value: busybox
```

https://kyverno.io/docs/exceptions/

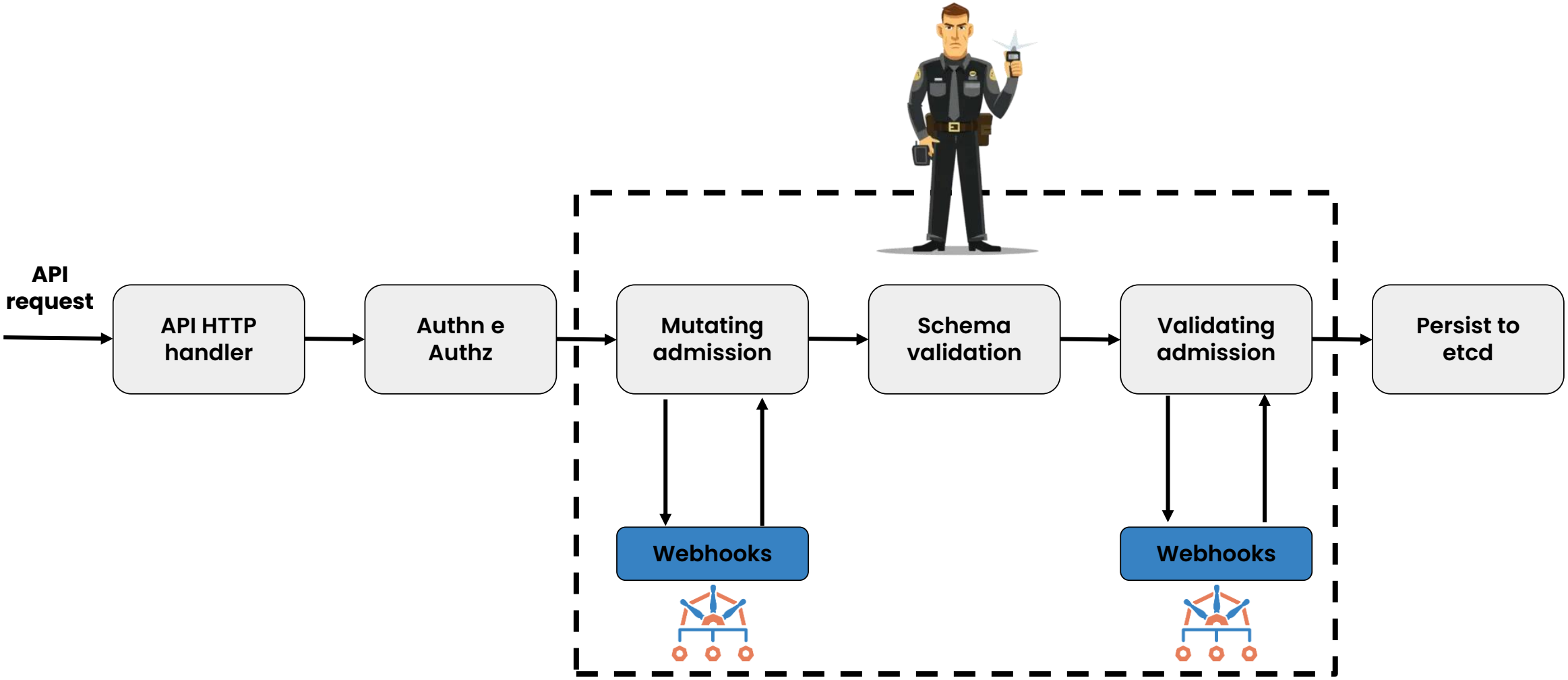
CleanupPolicy

- Cluster-wide
  - ClusterCleanupPolicy
- Namespace-wide
  - CleanupPolicy
- Faz a limpeza **periódica:**
  - elimina objetos
- Mantém as regras de compliance
  - reduz risco de vazamento
    - secret não utilizada
    - policy exceptions

```yaml
apiVersion: kyverno.io/v2alpha1
kind: ClusterCleanupPolicy
metadata:
  creationTimestamp: "2023-02-11T15:24:31Z"
  generation: 1
  labels:
    app.kubernetes.io/managed-by: kyverno
    kyverno.io/automated: "true"
    kyverno.io/generated-by-kind: PolicyException
    kyverno.io/generated-by-name: emergency-busybox
    kyverno.io/generated-by-namespace: falcon-dev
    policy.kyverno.io/gr-name: ur-dpfvn
    policy.kyverno.io/policy-name: automate-cleanup
    policy.kyverno.io/synchronize: disable
  name: polex-falcon-dev-emergency-busybox-y8mnuyyb
  resourceVersion: "1601278"
  uid: 8323279e-18a2-41f6-afc7-44a74db8f240
spec:
  match:
    any:
    - resources:
        kinds:
        - PolicyException
        names:
        - emergency-busybox
        namespaces:
        - falcon-dev
  schedule: 0 */4 * * *
```

https://kyverno.io/docs/policy-types/cleanup-policy/

Dynamic Admission Controller



https://kyverno.io/docs/introduction/admission-controllers/#about-dynamic-admission-controllers

Use cases

Explorando e remediando vulnerabilidades!

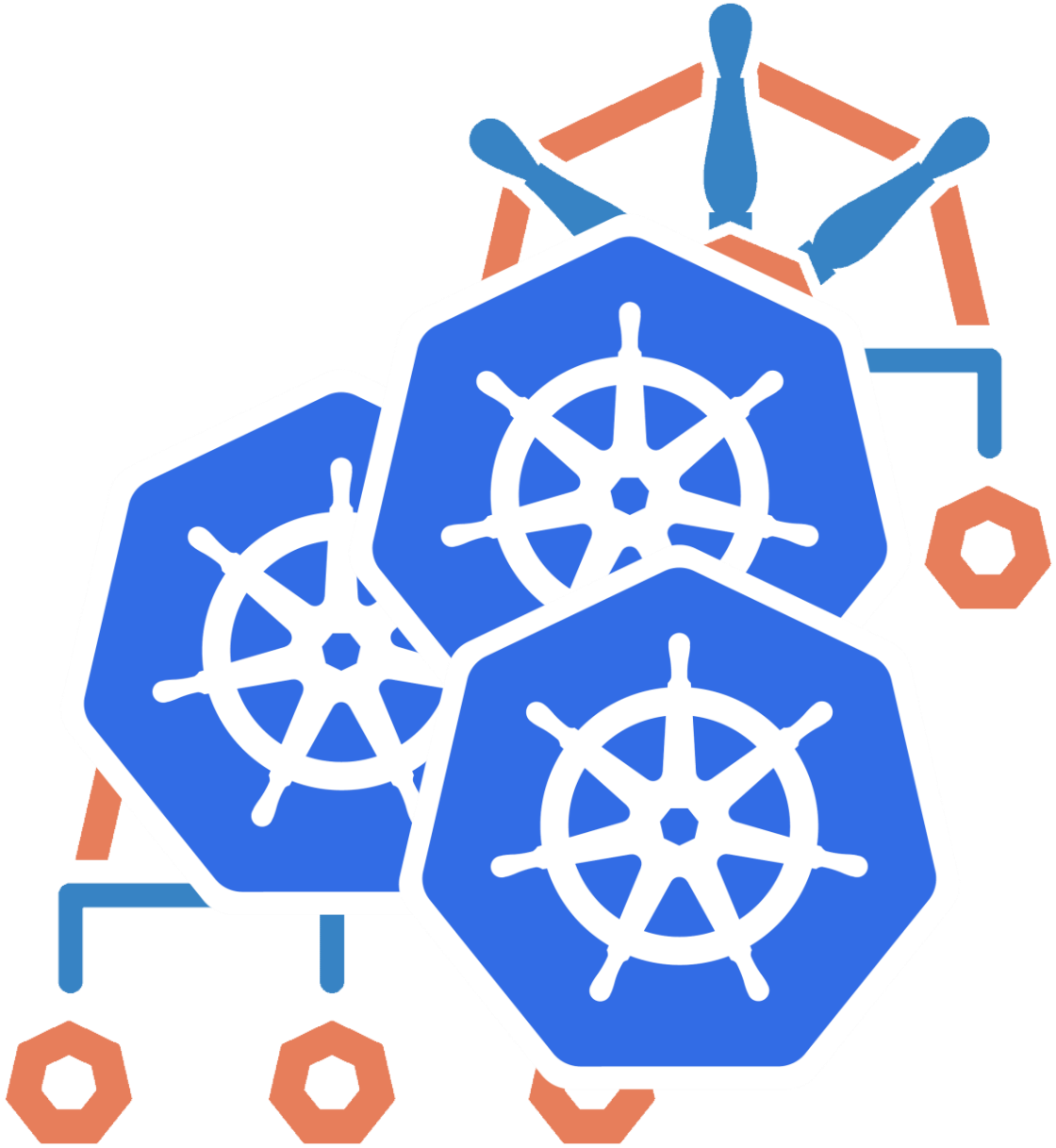


Imagem Docker

Dockerfile

```
FROM ubuntu:latest

# Instalação de pacotes
RUN apt-get update && apt-get install -y \
    bash \
    curl \
    wget \
    vim \
    python3 \
    ca-certificates && \
    apt-get clean && \
    rm -rf /var/lib/apt/lists/*

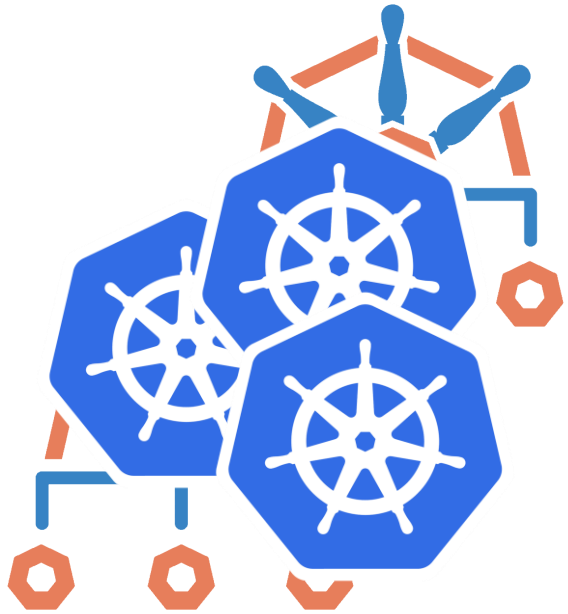
# Criar um usuário não-root
RUN groupadd -r appgroup && \
    useradd -r -g appgroup appuser

WORKDIR /home/appuser

RUN chown -R appuser:appgroup /home/appuser

USER appuser

CMD ["/bin/sh"]
```



Aplicando Seccomp com Cluster Policy

Impedindo chamadas ao kernel

Aplicando Seccomp

```
spec:
  containers:
  - args:
    - -c
    - sleep infinity
    command:
    - /bin/sh
    image: ubuntu-kyverno-test:v2
    imagePullPolicy: IfNotPresent
    name: kyverno-test-container
    resources: {}
    terminationMessagePath: /dev/termination-log
    terminationMessagePolicy: File
    volumeMounts:
    - mountPath: /var/run/secrets/kubernetes.io/serviceaccount
      name: kube-api-access-khbzt
      readOnly: true
  dnsPolicy: ClusterFirst
  enableServiceLinks: true
  nodeName: minikube
  preemptionPolicy: PreemptLowerPriority
  priority: 0
  restartPolicy: Always
  schedulerName: default-scheduler
  securityContext: {}
```

- **Permite escalação de privilégio**
  - **default: Unconfined**
- **Abre brecha para sair do container e acessar o host**

Aplicando Seccomp

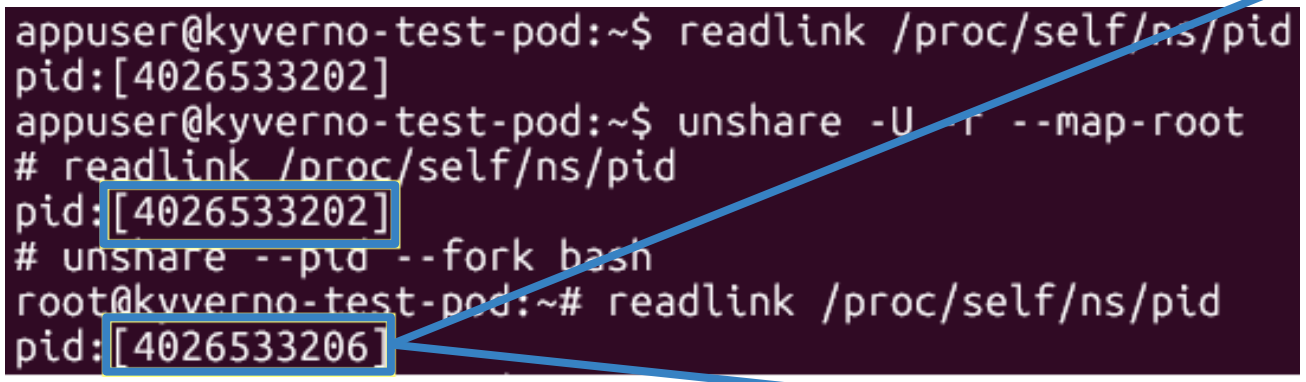
pod-kyverno-test.yaml > {} spec > [ ] containers > {} 0 >

```yaml
apiVersion: v1
kind: Pod
metadata:
  name: kyverno-test-pod
  namespace: kyverno-test
spec:
  containers:
  - name: kyverno-test-container
    image: ubuntu-kyverno-test:v2
    command: ["/bin/sh"]
    args: ["-c", "sleep infinity"]
    imagePullPolicy: IfNotPresent
  restartPolicy: Always
```

0	SECCOMP_MODE_DISABLED
1	SECCOMP_MODE_STRICT
2	SECCOMP_MODE_FILTER

```
appuser@kyverno-test-pod:~$ cat /proc/self/status | grep Seccomp
Seccomp:        0
Seccomp_filters:        0
```

Aplicando Seccomp



- **Cria um novo ambiente shell isolado do sistema principal**
- **Permite camuflar processos**
- **Permite interagir com processos do sistema “de fora”**
- **Faz chamada para a syscall fork**

Aplicando Seccomp

kyverno-policy-seccomp.yaml > ...

```yaml
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata: ···
spec:
  validationFailureAction: Enforce
  background: true
  rules:
    - name: "check-seccomp-runtime-default"
      match:
        any:
        - resources:
            kinds:
            - Pod
      validate:
        message: "Seccomp profile RuntimeDefault é obrigatório"
        pattern:
          spec:
            securityContext:
              seccompProfile:
                type: RuntimeDefault
      exclude:
        any:
        - resources:
            namespaces:
            - kyverno
```

! kyverno-policy-seccomp.yaml > ...

```yaml
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata: ···
spec:
  validationFailureAction: Enforce
  background: true
  rules:
    - name: "check-seccomp-runtime-default" ···
    - name: mutate-seccomp-profile
      match:
        any:
        - resources:
            kinds:
            - Pod
      mutate:
        patchStrategicMerge:
          spec:
            securityContext:
              +(seccompProfile):
                type: RuntimeDefault
      exclude:
        any:
        - resources:
            namespaces:
            - kyverno
```

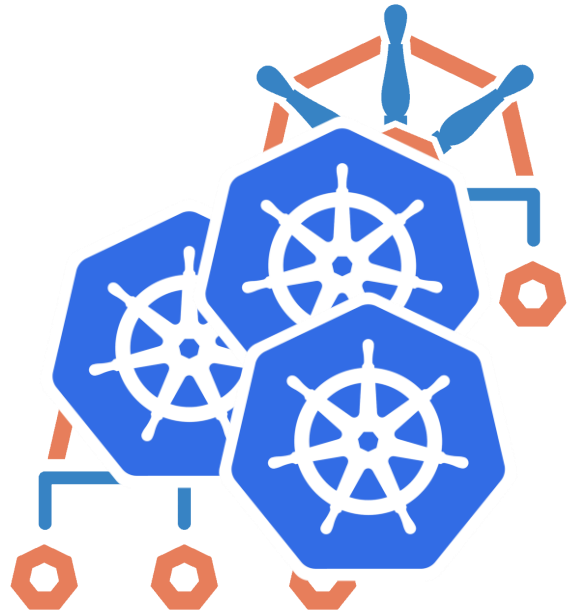
Aplicando Seccomp

```yaml
spec:
  containers:
  - args:
    - -c
    - sleep infinity
    command:
    - /bin/sh
    image: ubuntu-kyverno-test:v2
    imagePullPolicy: IfNotPresent
    name: kyverno-test-container
    resources: {}
    terminationMessagePath: /dev/termination-log
    terminationMessagePolicy: File
    volumeMounts:
    - mountPath: /var/run/secrets/kubernetes.io/serviceaccount
      name: kube-api-access-r2wjp
      readOnly: true
  dnsPolicy: ClusterFirst
  enableServiceLinks: true
  nodeName: minikube
  preemptionPolicy: PreemptLowerPriority
  priority: 0
  restartPolicy: Always
  schedulerName: default-scheduler
  securityContext:
    seccompProfile:
      type: RuntimeDefault
```

0	SECCOMP_MODE_DISABLED
1	SECCOMP_MODE_STRICT
2	SECCOMP_MODE_FILTER

```
appuser@kyverno-test-pod:~$ cat /proc/self/status | grep Seccomp
Seccomp:        2
Seccomp_filters:        1
```

```
appuser@kyverno-test-pod:~$ unshare -U -r --map-root
unshare: unshare failed: Operation not permitted
appuser@kyverno-test-pod:~$ unshare --pid --fork bash
unshare: unshare failed: Operation not permitted
```



Restringindo privilégios com ClusterPolicy

Impedindo interação com arquivos do host

Restringindo privilégios

pod-kyverno-test-privileged.yaml > ...

```yaml
apiVersion: v1
kind: Pod
metadata:
  name: kyverno-test-pod-privileged
  namespace: kyverno-test
spec:
  containers:
  - name: kyverno-test-container-privileged
    image: ubuntu-kyverno-test-privileged:v1
    securityContext:
      privileged: true
    volumeMounts:
    - mountPath: /mnt/host-data
      name: host-volume
  volumes:
  - name: host-volume
    hostPath:
      path: /etc/
      type: DirectoryOrCreate
  restartPolicy: Always
```

Restringindo privilégios

```
appuser@kyverno-test-pod-privileged:~$ ls -l /dev
total 0
crw------- 1 root root     10, 235 Nov 16 01:48 autofs
drwxr-xr-x 2 root root          120 Nov 16 01:48 bsg
crw------- 1 root root     10, 234 Nov 16 01:48 btrfs-control
lrwxrwxrwx 1 root root           11 Nov 16 01:48 core -> /proc/kcore
crw------- 1 root root     10, 123 Nov 16 01:48 cpu_dma_latency
crw------- 1 root root     10, 203 Nov 16 01:48 cuse
crw-rw-rw- 1 root root     10, 125 Nov 16 01:48 dxg
lrwxrwxrwx 1 root root           13 Nov 16 01:48 fd -> /proc/self/fd
crw-rw-rw- 1 root root      1,   7 Nov 16 01:48 full
crw-rw-rw- 1 root root     10, 229 Nov 16 01:48 fuse
crw------- 1 root root     10, 228 Nov 16 01:48 hpet
crw------- 1 root root    229,   0 Nov 16 01:48 hvc0
crw------- 1 root root    229,   1 Nov 16 01:48 hvc1
crw--w---- 1 root tty     229,   2 Nov 16 01:48 hvc2
crw------- 1 root root    229,   3 Nov 16 01:48 hvc3
crw------- 1 root root    229,   4 Nov 16 01:48 hvc4
crw------- 1 root root    229,   5 Nov 16 01:48 hvc5
crw------- 1 root root    229,   6 Nov 16 01:48 hvc6
crw------- 1 root root    229,   7 Nov 16 01:48 hvc7
crw------- 1 root root     10, 183 Nov 16 01:48 hwrng
crw-r--r-- 1 root root      1,  11 Nov 16 01:48 kmsg
crw-rw---- 1 root     103  10, 232 Nov 16 01:48 kvm
crw-rw---- 1 root disk     10, 237 Nov 16 01:48 loop-control
brw-rw---- 1 root disk      7,   0 Nov 16 01:48 loop0
brw-rw---- 1 root disk      7,   1 Nov 16 01:48 loop1
brw-rw---- 1 root disk      7,   2 Nov 16 01:48 loop2
```

- Acesso total aos **dispositivos** do host
- Acesso de **root** no host
- Montar file system

Restringindo privilégios

```
appuser@kyverno-test-pod-privileged:~$ cat /mnt/host-data/hosts
127.0.0.1       localhost
::1     localhost ip6-localhost ip6-loopback
fe00::  ip6-localnet
ff00::  ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
192.168.49.2    minikube
192.168.49.1    host.minikube.internal
192.168.49.2    control-plane.minikube.internal
```

Restringindo privilégios

```yaml
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: require-privileged-false
  namespace: kyverno
  annotations: ···
spec:
  validationFailureAction: Enforce
  background: true
  rules:
  - name: "check-privileged-false"
    match:
      any:
      - resources:
          kinds:
          - Pod
    validate:
      message: "Container não pode rodar com privileged: true"
      pattern:
        spec:
          containers:
          - securityContext:
              privileged: false
    exclude:
      any:
      - resources:
          namespaces:
          - kyverno
```

```yaml
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: require-privileged-false
  namespace: kyverno
  annotations: ···
spec:
  validationFailureAction: Enforce
  background: true
  rules:
  - name: "check-privileged-false" ···
  - name: "mutate-privileged-false"
    match:
      any:
      - resources:
          kinds:
          - Pod
    mutate:
      patchStrategicMerge:
        spec:
          containers:
          - securityContext:
              +(privileged): false
    exclude:
      any:
      - resources:
          namespaces:
          - kyverno
```

Restringindo privilégios

pod-kyverno-test-privileged.yaml > ...

```yaml
apiVersion: v1
kind: Pod
metadata:
  name: kyverno-test-pod-privileged
  namespace: kyverno-test
spec:
  containers:
  - name: kyverno-test-container-privileged
    image: ubuntu-kyverno-test-privileged:v1
    securityContext:
      privileged: true
    volumeMounts:
    - mountPath: /mnt/host-data
      name: host-volume
  volumes:
  - name: host-volume
    hostPath:
      path: /etc/
      type: DirectoryOrCreate
  restartPolicy: Always
```

Restringindo privilégios

```
flaviomeira10@DESKTOP-GOL18DP:~/estudo/kyverno$ kubectl -n kyverno-test apply -f pod-kyverno-test-privileged.yaml
Error from server: error when creating "pod-kyverno-test-privileged.yaml": admission webhook "validate.kyverno.svc-fail" denied the request:

resource Pod/kyverno-test/kyverno-test-pod-privileged was blocked due to the following policies

require-privileged-false:
  check-privileged-false: 'validation error: Container não pode rodar com privileged:
    true. rule check-privileged-false failed at path /spec/containers/0/securityContext/privileged/'
```

Policies Aplicadas

```yaml
spec:
  containers:
  - args:
    - -c
    - sleep infinity
    command:
    - /bin/sh
    image: ubuntu-kyverno-test:v2
    imagePullPolicy: IfNotPresent
    name: kyverno-test-container
    resources: {}
    securityContext:
      privileged: false
    terminationMessagePath: /dev/termination-log
    terminationMessagePolicy: File
    volumeMounts:
    - mountPath: /var/run/secrets/kubernetes.io/serviceaccount
      name: kube-api-access-xxxd6
      readOnly: true
  dnsPolicy: ClusterFirst
  enableServiceLinks: true
  nodeName: minikube
  preemptionPolicy: PreemptLowerPriority
  priority: 0
  restartPolicy: Always
  schedulerName: default-scheduler
  securityContext:
    seccompProfile:
      type: RuntimeDefault
  serviceAccount: default
```

privileged: false

- Garante que nenhuma pod tenha acesso ao host
- Não permite acessar os dispositivos do host
- Não permite montar arquivos do host nos containers

seccomp profile

- Policy que garante que nenhuma pod tenha a configuração seccomp profile insegura
- Bloqueia chamadas perigosas no kernel
- Diminui muito o risco de “escapar do container” e acessar o host

Métricas

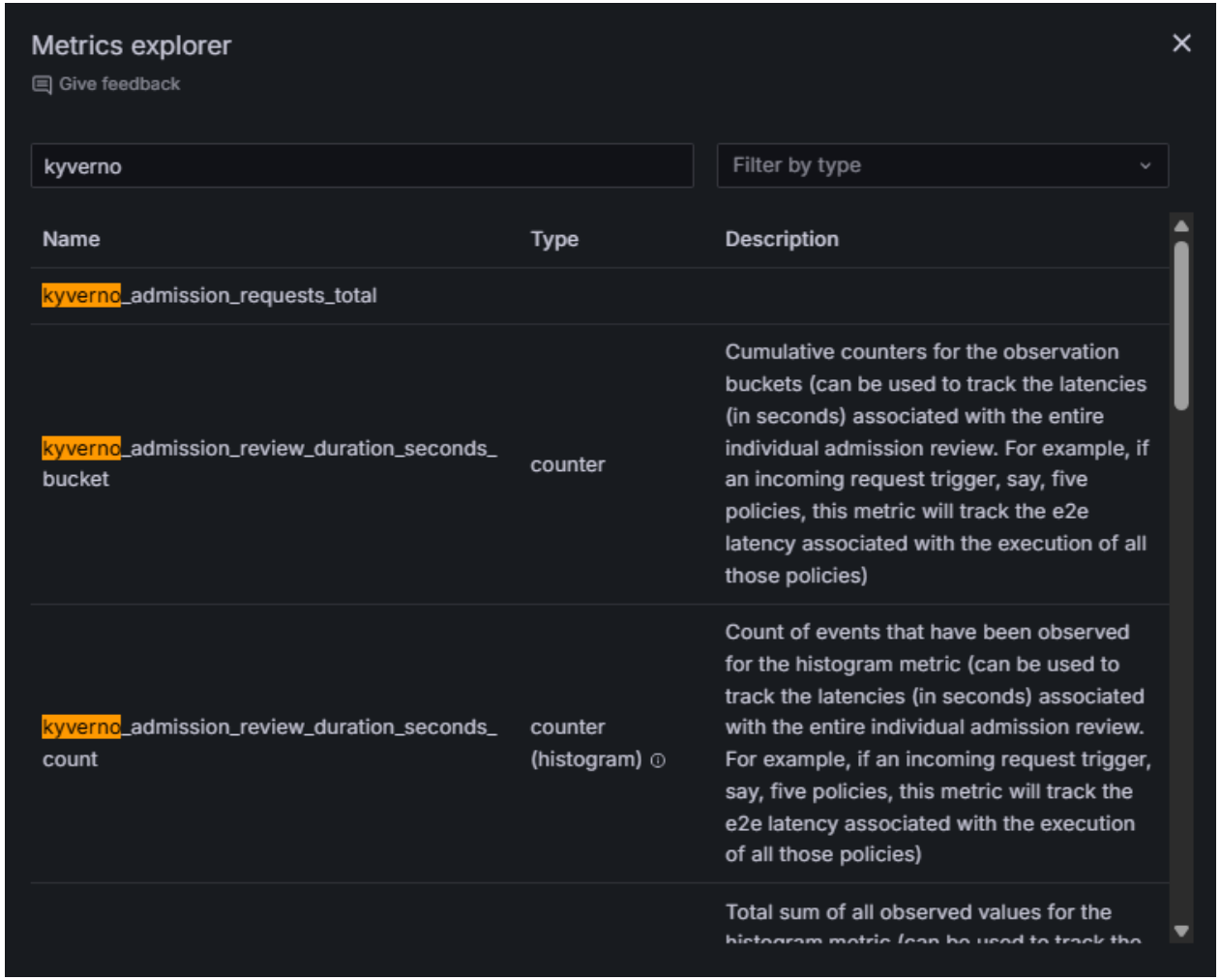
Monitorando as operações de segurança



Métricas

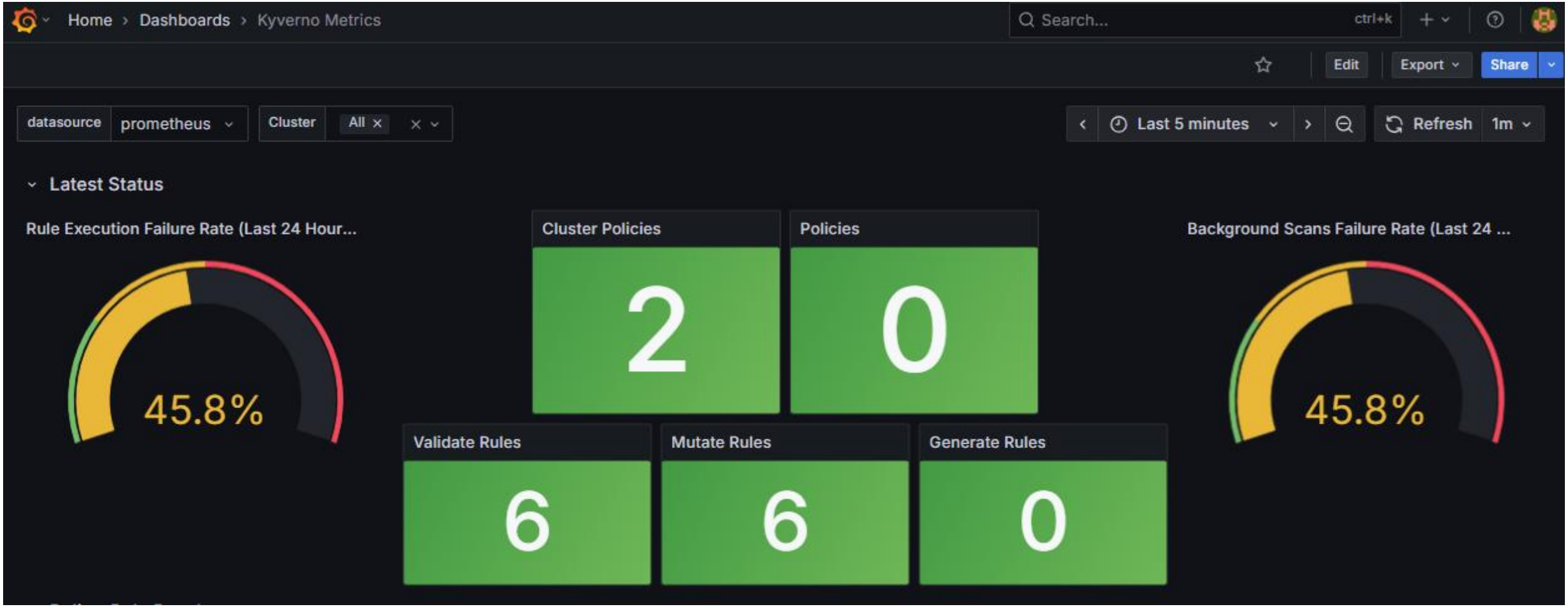
- Expõe as métricas para o Prometheus
  - Total de policies aplicadas
  - Latência
    - Tempo de processamento das requests analisadas
    - Tempo de aplicação das mutações
  - Total de requisições de Admission

- Dashboard Grafana mantido pela comunidade



https://kyverno.io/docs/monitoring/

Métricas


Home › Dashboards › Kyverno Metrics
Search...
ctrl+k
Edit
Export
Share
datasource
prometheus
Cluster
All
Last 5 minutes
Refresh
1m
Latest Status
Rule Execution Failure Rate (Last 24 Hour...
45.8%
Cluster Policies
2
Policies
0
Validate Rules
6
Mutate Rules
6
Generate Rules
0
Background Scans Failure Rate (Last 24 ...
45.8%

Obrigado!

